TITLE:

SQL INJECTION ATTACKS AND THEIR PREVENTION IN WEB APPLICATIONS

NAME : FATIMA RAMZAN

ROLL NO : BITF24A029

SECTION: AFTERNOON

SUBJECT: INFORMATION SECURITY

INTRODUCTION

- Web applications store sensitive data in databases.
- Poor input validation can lead to SQL Injection attacks.
- Attackers manipulate SQL queries using user input.
- This project shows attack and prevention techniques.

PROBLEM STATEMENT

- Many web applications are insecure due to weak input validation.
- SQL Injection allows attackers to:
- Bypass login systems
- Access confidential data
- Modify or delete database records

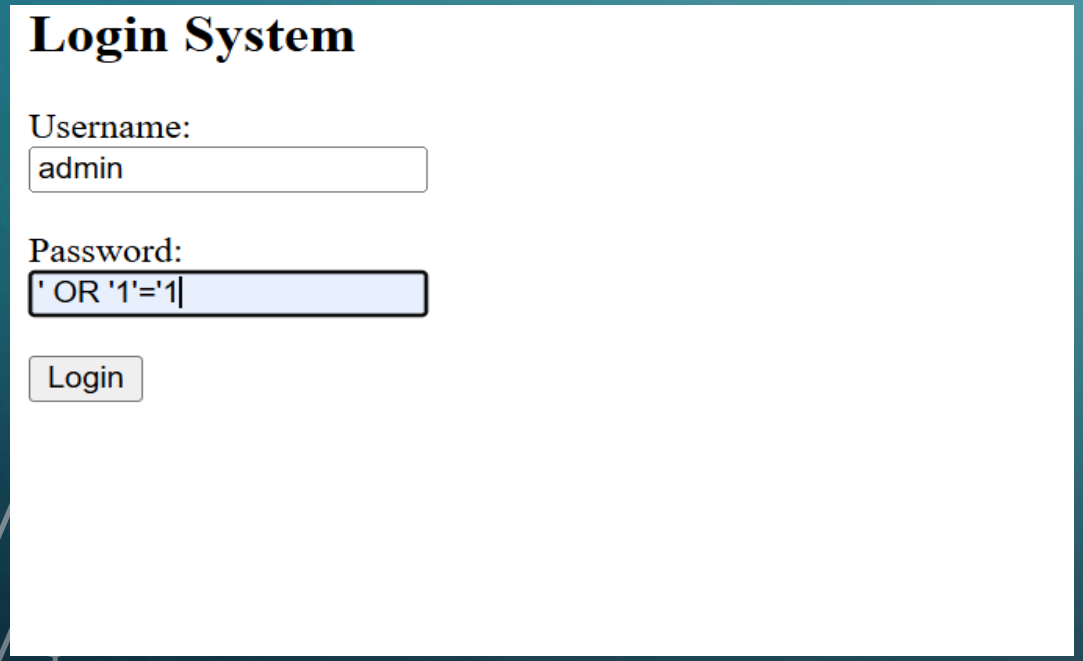
WHAT IS SQL INJECTION?

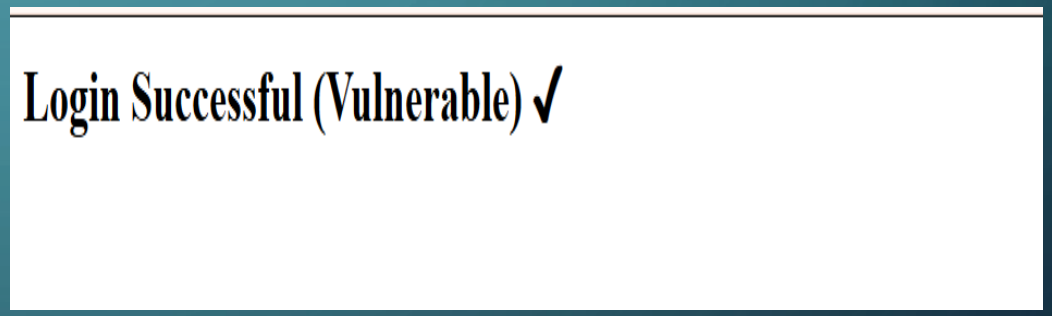
- SQL Injection is a web security vulnerability.
- It occurs when attackers insert malicious SQL code.
- It changes the behavior of database queries.
- It is one of the most dangerous web attacks.

HOW SQL INJECTION WORKS

- User input is directly included in SQL query.
- Attacker modifies input to change query logic.
- Database executes unintended commands.
- Leads to unauthorized access.

ATTACK EXAMPLE (DEMO INPUT)





Vulnerable SQL Query

```
SELECT * FROM users WHERE username='$user' AND password
='$pass';
```

- Direct insertion of user input
- No validation or sanitization
- Highly insecure

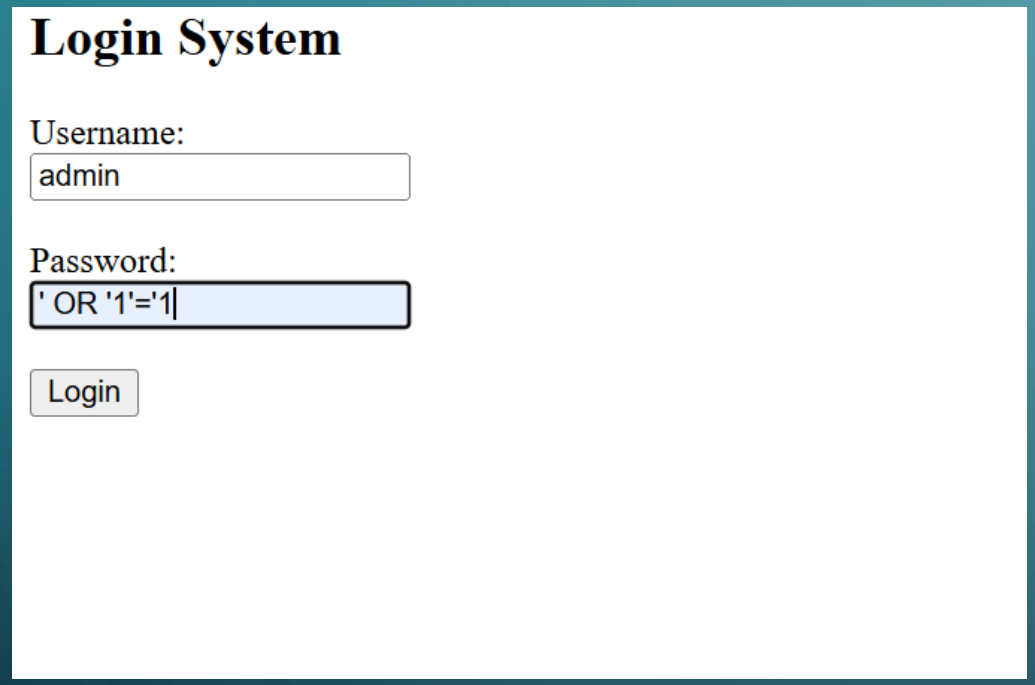
IMPACT OF SQL INJECTION

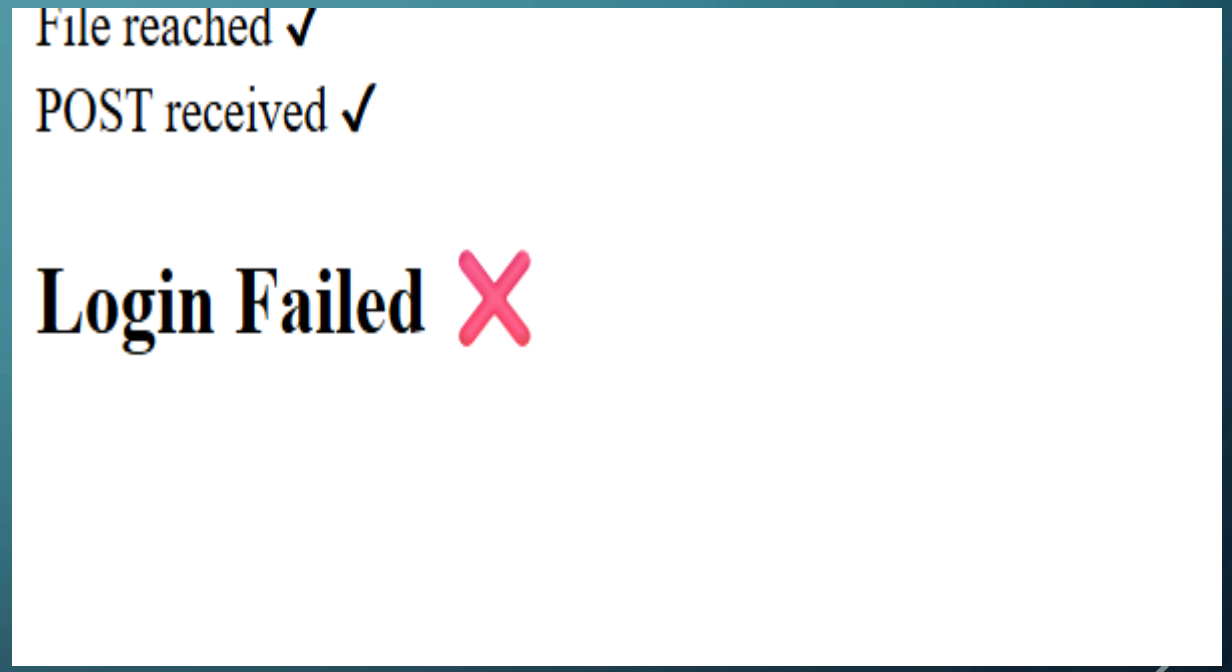
- Unauthorized login access
- Data theft
- Database modification or deletion
- Complete system compromise

PREVENTION TECHNIQUES

- Prepared Statements
- Parameterized Queries
- Input Validation
- Least Privilege Principle

SECURE EXAMPLE





SECURE CODE EXAMPLE

```
$stmt = $conn->prepare("SELECT * FROM users WHERE username=? AND
password=?");
$stmt->bind_param("ss", $user, $pass);
```

- Input treated as data only
- Prevent query manipulation
- Secure against sql injection

WORKING

- Vulnerable system allows attack using special input
- Secure system blocks malicious input
- Demonstration shows difference clearly
- Both versions tested in project

CONCLUSION

- SQL Injection is a serious security threat
- It occurs due to unsafe coding practices
- Secure coding prevents attacks effectively
- Prepared statements are the best solution

thank you